

Defense 4 — meeting reference sheet

One-switch DNP3 obfuscation (RRC segmentation/CLRT + BOR bounded-OPERATE-release), physical SEL-751. Authoritative state: `commit 5a0fb73`, branch `defense4-size-native-parity-crc-split`.

The three speaking levels

30 seconds. A DNP3 relay can be fingerprinted from traffic alone — the size of its responses, how they are segmented, and a timing feature called CLRT (the gap between the TCP ACK and the DNP3 answer). We put one Intel Tofino-1 switch inline in front of a real SEL-751 relay and rewrote that traffic in-network, without changing a single DNP3 byte: every response now leaves as the same two segments and the same ~4 ms CLRT, and control commands are (by design) released on a hidden delay. On silicon the relay’s native CLRT and segment-shape fingerprint is replaced by a fixed policy, and no output actuated — all 32 relay outputs stayed OPEN throughout.

3 minutes. DNP3 masters poll relays over TCP. A passive observer who cannot read payloads can still tell devices apart by three features: *response size*, *TCP segmentation*, and $CLRT = T_{response} - T_{TCP-ACK}$ (Formby et al.). Our defense is two primitives on one Tofino-1 pipe. **RRC** recirculates each READ/SELECT response on an internal loopback (dp8) and splits it at a block-aligned carve point (chosen, not required by TCP) — the SEL’s 49-byte response becomes segments **[28, 21]**, byte-preserving, no CRC recomputed (total length unchanged) — and holds it to a fixed CLRT deadline. **BOR** handles the Select-Before-Operate OPERATE: by design it admits one matching OPERATE, holds it on a *second* internal loopback (dp10), and releases it once at a secret delay **$T_0 + J$** , while the ACK and echo the master sees stay pinned to the original arrival T_0 . That last property is the key: because the ACK is at $T_0 + A$ and the echo at $T_0 + R$ regardless of J , the observable **$echo - ACK = R - A$** is constant, so the hidden J cannot be subtracted out. Measured on the physical relay: native CLRT (1.3 ms READ / 2.1 ms SELECT, high variance) becomes **4.001 ms, std 0.02**; native **[49]** becomes **[28, 21]** with zero escapes; $echo - ACK$ holds at **4.00 ms** across $J = 2, 6, 12$ ms; an attacker’s READ-vs-SELECT classifier falls from 0.59 to chance (0.50); and all 32 relay outputs stay OPEN.

Detailed (for Dr. Lin). See §4–§13 of the full explainer. The load-bearing engineering result is that RRC + BOR fit in **one** Tofino pipe at **≤ 12 ingress MAU stages** via a decision-table flatten (the whole match-action tail collapses to one computed `meta.outcome` applied by one terminal `tbl_commit`), and that BOR needs a **second scheduling domain** (dp10) so its OPERATE-hold queues are not starved by the ACK/response reservoirs RRC seeds on dp8. The honest boundary: the master-facing observables are proven on silicon; the relay-facing internal release ($T_0 + J$) and exactly-once delivery are *inferred*, not captured (dp68 is an internal port, not a tap).

Equations

- Fingerprint feature: **$CLRT = T_{response} - T_{TCP-ACK}$**
- One notation, anchored to arrival T_0 : **$T_{ACK} = T_0 + A$, $T_{response} = T_0 + R$, $CLRT = R - A$**
- RRC final campaign: **$A = 20$ ms** (= knob D_A), **$R = 24$ ms** (= $D_A + D_R$, $D_R = 4$ ms gap after ACK) $\Rightarrow$ **$CLRT = 24 - 20 = 4$ ms**. Master-facing ~21/25 ms includes ~1 ms path/capture offset.
- BOR release: **$T_{OP,out} = T_0 + J$** (J from a bounded codebook; *by design*, relay-facing not captured)
- BOR observables: **$T_{ACK} = T_0 + A$, $T_{echo} = T_0 + R$** , so **$T_{echo} - T_{ACK} = R - A$** , independent of J (measured on silicon)

Verified results (commit 5a0fb73)

Quantity	Native	Defended	Source
Response segmentation	100 × [49]	1280 × [28,21], 0 escapes	<code>size_verdict.csv</code> , <code>VERDICT.json</code>
DNP3 block-CRC + IP/TCP checksum valid	—	1280 / 1280	<code>size_reconstruct.py</code>

Quantity	Native	Defended	Source
CLRT READ (median/std)	1.272 ms / 1.354	4.001 / 0.022	verdict_stats.json
CLRT SELECT (median/std)	2.107 ms / 2.530	4.001 / 0.021	verdict_stats.json
BOR echo – ACK, J=2/6/12	—	4.00 ms, std 0.026 (J-independent)	sbo_j*.csv
MI(class; CLRT), common-bins	0.424 bits	0.0018 bits (within perm-null)	verdict_stats.json
READ-vs-SELECT classifier BA	0.592	0.500 (chance)	verdict_stats.json
Relay outputs	—	all 32 OPEN , index-6 refused	readbacks/relay_outputs_final.
Pipe / stage fit	—	1 pipe, ≤12 ingress stages	compile logs

What is claimed / NOT claimed

- **PASS:** timing (CLRT) normalization; segmentation / packet-shape normalization for eligible 49-byte responses (per-packet [28,21] + count parity, total length unchanged); Formby CLRT feature-suppression (READ-vs-SELECT); testbed unchanged; safety (no actuation, all 32 OPEN).
- **PARTIAL / NOT demonstrated:** exactly-once BOR delivery (relay-facing T0+J and multiplicity not captured — dp68 is internal).
- **NOT claimed:** multi-device indistinguishability (single SEL-751 → signature *replacement*, not anonymity); byte-identical-to-source (no source-frame oracle — only CRC/checksum-valid 49-B reconstruction); session-disjoint classifier split (it is transaction-disjoint, one session).

Likely questions — short answers

- **Why delay both the ACK and the response to hide CLRT?** CLRT is a *difference*. Fixing only one endpoint still leaks the other; pinning both to policy deadlines makes the difference a constant.
- **Why is J needed at all?** Without a hidden per-transaction release, the OPERATE’s true latency is observable. J randomizes the internal release; anchoring ACK/echo to T0 keeps J unsubtractable.
- **Why two loopback ports?** BOR seeds ACK/response blockers on RRC’s high-priority queues (dp8). On one shared strict-priority scheduler those blockers would starve the OPERATE-hold queues, so the OPERATE could not be released on its own T0+J deadline. dp10 gives BOR an independent scheduler.
- **Does [28,21] really hide size if the total is still 49?** The defended claim is *segmentation* + *per-response O-count parity*, not payload-length hiding. Every response — READ, SELECT, OPERATE — now presents the identical two-segment shape, so the observer cannot separate transaction classes by shape. Length alone was never the whole signature; segmentation and CLRT were.
- **Can the attacker just reassemble TCP?** A full TCP reassembler recovers the 49 bytes, yes — but the *fingerprintable network features* (segment boundaries, CLRT, timing) are what we normalize. The threat model is passive feature-based fingerprinting, not payload confidentiality.
- **What happens on retransmission?** By design a retransmitted OPERATE after release reads the spent-epoch marker → classified duplicate → dropped (not re-forwarded); this closed a defect (Blocker 5) and is model-verified. The relay-facing side was not captured.
- **Why is exactly-once still PARTIAL?** The master issued one OPERATE per transaction and no output actuated (all 32 OPEN), but we did not capture the relay-facing wire, so single-delivery is inferred, not measured.
- **How is this different from software traffic shaping?** It runs in the switch dataplane at line rate with no proxy, no TCP termination, and no DNP3 byte modification — the master and relay speak end-to-end; the switch only re-segments and re-times.

- **What is novel on Tofino?** Fitting a stateful hold/release + CRC-boundary split for a real industrial protocol in one pipe at ≤ 12 stages, and the two-scheduling-domain trick that makes a bounded-OPERATE-release coexist with response normalization on a single switch.